PENETRATION TESTING REPORT

FOOTPRINTING & NETWORK SCANNING PHASES

W2-PM-FINAL | CYBERSECURITY | NETWORKWALKS

Pentester Name (Cybersecurity Professional)	KOMAL
Program/Batch	B084B-Networkwalks
Date	13 November 2026
Modules completed	W2-PM1 (Multiple Kali Tools) W2-PM4(Footprinting with the theHarvester) W2-PM5 (Zenmap Scanning)
Client/Target	1. Networkwalks (secured written permission already) 2. My Kali network 3. microsoft.com (passive OSINT with theHarvester only, public sources)
Permission secured from client?	Yes (Networkwalks and my own network). theHarvester queries were passive only.
Phases covered	**Phase 1:** Reconnaissance & Footprinting **Phase 2:** Scanning & Network Discovery **Phase 3-5:** In Progress

1. Liability Disclaimer

I have performed these activities only on the systems & devices where I had secured written permission or the devices/systems that I own myself. All these materials are for education and research purpose only. Do not use anything from here to break the law. The instructor, the authors and Networkwalks are not responsible for what you do with this knowledge. Every action you take is your own responsibility. Misuse can lead to criminal charges, heavy fines, loss of your job and a permanent record. In most countries unauthorised access is a crime even when nothing is damaged.

2. Introduction

This report covers footprinting the networkwalks.com domain using six Kali Linux tools (W2-PM1), and theHarvester (W2-PM4) and scanning my own local network with Zenmap, the graphical front end of Nmap (W2-PM5). One module covers the footprinting phase and the other covers the scanning phase, so together they show how an attacker moves from gathering public information to mapping live hosts on a network. It is the Week 2 part of my ongoing internship program at Networkwalks.
All commands were run in Kali Linux virtual machines (footprinting and OSINT). Every step below includes the exact command used, the result I observed, and a screenshot as evidence in Section 8, with a short note on why the finding matters from an attacker's point of view.

3. Tools Used

The table below lists each tool used in this report and its purpose.

Tool	Purpose
Kali Linux & Windows	Operating systems used for reconnaissance and scanning activities
WHOIS	Find domain registration details (registrar, dates, name servers).
whatweb	Fingerprint web technologies (server, CMS, plugins, IP).
nslookup	Resolve the domain name to its IP address using DNS.
curl -I	Read the HTTP response headers of the website.
wafw00f	Detect whether a Web Application Firewall protects the site.
dnsrecon	Enumerate DNS records (SOA, NS, MX, A, TXT, SRV).
theHarvester	Collect public OSINT data (emails, hosts, IPs) from open sources.
Zenmap (Nmap GUI)	Scan the local subnet to find live hosts, IPs and MAC addresses.
Bash commands :ip -4 addr , ip route	Local IP address, subnet mask and gateway identification

4. Activities Performed

4.1 Footprinting & Reconnaissance

I performed reconnaissance against the networkwalks.com domain using six Kali Linux tools: **WHOIS, WhatWeb, Nslookup, Curl, Wafw00f and DNSRecon**. Each tool was used to collect a different type of information about the target.

First, I ran whois networkwalks.com to obtain public domain registration information. The domain is registered through **GoDaddy.com, LLC**. It was created on **6 November 2019**, last updated on 12 November 2025 and expires on **6 November 2027**. The name servers are **NS6135.HOSTGATOR.COM** and **NS6136.HOSTGATOR.COM**, which shows the site is hosted with HostGator. The domain has four client lock statuses (delete, renew, transfer and update prohibited) and **DNSSEC is unsigned**.

I then ran whatweb networkwalks.com to identify the technologies used by the website. The HTTP address returned a **301 redirect** to HTTPS, and the HTTPS site returned **200 OK**. WhatWeb identified **Apache** as the web server, **WordPress 7.1.4** with **WP Download Manager 3.3.76**, **jQuery 3.7.1** and **Bootstrap**. It also exposed the server IP **192.232.216.135** (United States), the contact email **info@networkwalks.com**, the page title **Networkwalks Academy** and a __wpdm_client cookie with the HttpOnly flag.

Using nslookup networkwalks.com (DNS server 8.8.8.8), I resolved the domain name to its IP address. The non-authoritative answer returned **192.232.216.135**, which matches the IP address shown by WhatWeb.

I used curl -I https://networkwalks.com to inspect the HTTP response headers. The server replied **HTTP/1.1 200 OK** and identified itself as **Apache**. The Link header exposed the WordPress REST API endpoint **/wp-json/**, and headers such as X-nginx-cache: WordPress and X-Endurance-Cache-Level revealed caching details. The __wpdm_client cookie was set with the Secure and HttpOnly flags. I did not see Strict-Transport-Security, X-Frame-Options or Content-Security-Policy headers in this response.

Next, I ran wafw00f networkwalks.com (WAFW00F v2.4.2) to determine whether a Web Application Firewall was protecting the website. After 2 requests, the result identified **ModSecurity (SpiderLabs)**.

Finally, I ran dnsrecon -d networkwalks.com to enumerate DNS records. The results showed the **SOA** and **NS** records (ns6135.hostgator.com at 50.87.144.87 and ns6136.hostgator.com at 192.232.216.131), both running **BIND 9.16.23-RH**; an **MX** record (mail.networkwalks.com at 192.232.216.135); an **A** record (192.232.216.135); two **TXT** records, including the SPF policy v=spf1 +a +mx +ip4:50.87.144.87 +include:websitewelcome.com ~all and a Google site-verification record; and eight **SRV** records for cPanel email autodiscovery on port 443. DNSRecon also reported an error because there was no answer to its DNSSEC query.

4.2 OSINT with theHarvester

I used **theHarvester 4.11.1** to collect publicly available information (emails, hosts, IP addresses and names) about a domain from open sources. I used microsoft.com as a well-known public domain for this demonstration. The queries were passive: theHarvester only asked search engines and public data sources and did not scan or connect to the target's own servers.

In the first run I used theHarvester -d microsoft.com -l 1000 -b baidu, which searches the Baidu search engine with a limit of 1000 results. It finished with **no IPs, no emails, no people and no hosts found**.

In the second run I used theHarvester -d microsoft.com -l 50 -b all to query every supported source. Many sources failed with **Missing API key** messages (for example BeVigil, Bitbucket, BuiltWith, Brave Search, Censys, CriminalIP and Dehashed) because no API keys were configured in /etc/theHarvester/api-keys.yaml. This showed me that theHarvester returns limited results unless API keys are added for the sources that require them.

4.3 Network Scanning with Zenmap

For the final activity, I used **Zenmap** (the graphical interface of **Nmap 7.991**) to perform network discovery on my local network. The practical required me to identify my local IP address and subnet, discover live hosts, identify their IP and MAC addresses, and generate a network topology.

I ran the **ip -4 addr** and **ip route** commands on Kali terminal. My active IPv4 address was **10.0.0.2**, subnet mask **255.255.255.0** and default gateway **10.0.0.1**, so my local subnet is **10.0.0.0/24**.

I entered 10.0.0.0/24 as the target in Zenmap and selected the **Ping scan** profile, which runs nmap -sn 10.0.0.0/24. The scan started on 11 November 2026 and checked 256 IP addresses in **2.99 seconds**. It found **2 live hosts**:

- 10.0.0.1 (default gateway), MAC address 52:54:00:12:35:00
- 10.0.0.2 (my own Windows PC)

Nmap could not match either MAC address to a manufacturer (shown as "Unknown"). Both addresses are locally administered, which usually means the devices use private (randomized) MAC addresses, as many modern phones do.

After completing the scan, I opened the **Topology** tab in Zenmap, enabled the legend and saved the network topology in PDF format (topo.pdf) as required by the practical task. Both screenshots are included in Section 8.

5. Risk Analysis / Impact

Based on the information collected during the footprinting and network scanning activities, I identified the following potential risks.

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
1	Web technology information exposed	WhatWeb identified WordPress 7.1.4 and WP Download Manager 3.3.76	Attackers may use exposed technology/version information to identify software requiring further security review	● **Medium**
2	Server IP address identifiable	Nslookup resolved the domain to 192.232.216.135	Provides information about the network location of the web service	● **Low**
3	HTTP technical information exposed	Curl showed the Apache server, /wp-json/ REST API link and cache headers; no HSTS, X-Frame-Options or CSP header seen	May assist technology fingerprinting and further enumeration	● **Low**
4	WAF technology identifiable	Wafw00f identified ModSecurity (SpiderLabs)	Reveals information about the web application's security architecture	● **Low**
5	DNS infrastructure information exposed	DNSRecon listed NS, MX, SPF and SRV records, and BIND 9.16.23-RH on both name servers	DNS information can help build a broader infrastructure profile; software versions help targeted research	● **Medium**
6	DNSSEC not enabled	WHOIS showed DNSSEC "unsigned"; DNSRecon got no answer to its DNSSEC query	DNS answers cannot be cryptographically verified, which makes DNS spoofing easier in theory	● **Low**
7	Multiple live hosts visible on local network	Zenmap found 2 live hosts (1 MAC address) on 10.0.0.0/24	Unknown or unauthorized devices may be present on a network	● **Low**

Risk level key: ● Critical ● Medium ● Low

The risks above are observations from the footprinting and scanning exercises, not confirmed vulnerabilities.

The practical exercises primarily involved information gathering and host discovery. No exploitation or vulnerability validation was performed as part of this work.

Therefore, the presence of information such as a software version, IP address or DNS record does not by itself mean that the system is vulnerable. Further authorized security testing would be required to confirm any actual vulnerability.

6. Recommendations

Based on the observations from these activities, I recommend the following security improvements:

1. **Review publicly exposed technology information**
   Organizations should regularly review what information about their web technologies, CMS and plugins is publicly visible.
2. **Keep software updated**
   CMS platforms, plugins and other web technologies should be regularly updated and reviewed against current security advisories.
3. **Review HTTP headers**
   HTTP response headers should be reviewed to remove unnecessary technical information (server details, REST API links, cache headers) and to add security headers such as HSTS, X-Frame-Options and Content-Security-Policy where suitable.
4. **Review DNS records regularly**
   DNS records should be checked periodically to ensure that only required information and services are publicly exposed, and software version banners (for example BIND) should be hidden.
5. **Enable DNSSEC and review email authentication**
   Enable DNSSEC for the domain and consider tightening the SPF policy (currently ~all, soft fail) once all legitimate mail senders are listed.
6. **Properly configure and monitor the WAF**
   Keep the WAF (ModSecurity) enabled and tuned, since it already blocks naive attacks.
7. **Limit what OSINT tools can find**
   Review which emails, hosts and subdomains are publicly discoverable (for example with theHarvester) and remove anything that is not needed.
8. **Perform regular internal network discovery**
   Organizations should periodically scan their own networks to identify active devices.
9. **Investigate unknown devices**
   Any unexpected device discovered during network scanning should be investigated and verified.
10. **Maintain network documentation**
    Network topology and device information should be documented and updated regularly.
11. **Perform security testing with authorization**
    Reconnaissance and scanning should only be performed against systems and networks where appropriate authorization has been provided.

7. Conclusion

During Week 2 of my Cybersecurity & Ethical Hacking internship, I completed practical activities covering footprinting, reconnaissance, OSINT collection and network scanning.

In the footprinting activity, I used six Kali Linux tools to collect information about networkwalks.com. I learned how WHOIS can provide domain registration details, WhatWeb can identify web technologies, Nslookup can resolve domain names, Curl can inspect HTTP headers, Wafw00f can identify a WAF, and DNSRecon can enumerate DNS records. I also used theHarvester for passive OSINT and learned that many of its sources need API keys before they return results.

In the network scanning activity, I used Zenmap to identify my local network configuration (10.0.0.0/24), discovered two live hosts, collected their IP and MAC address information and saved a network topology.

The exercises showed me that information gathering is an important part of cybersecurity. Even before attempting to exploit a system, a security professional can learn a significant amount about an environment by carefully analyzing publicly available information and network responses.

I also learned that technical findings should be documented clearly. A good cybersecurity report should explain what was performed, what was discovered, what the observation means, what risk it may create, and what can be done to reduce that risk.

Finally, I learned that reconnaissance and scanning must always be performed within an authorized scope. These activities were completed as part of the assigned educational cybersecurity lab.

8. Evidences Collected

Figure 1: WHOIS lookup of networkwalks.com (`whois networkwalks.com`)

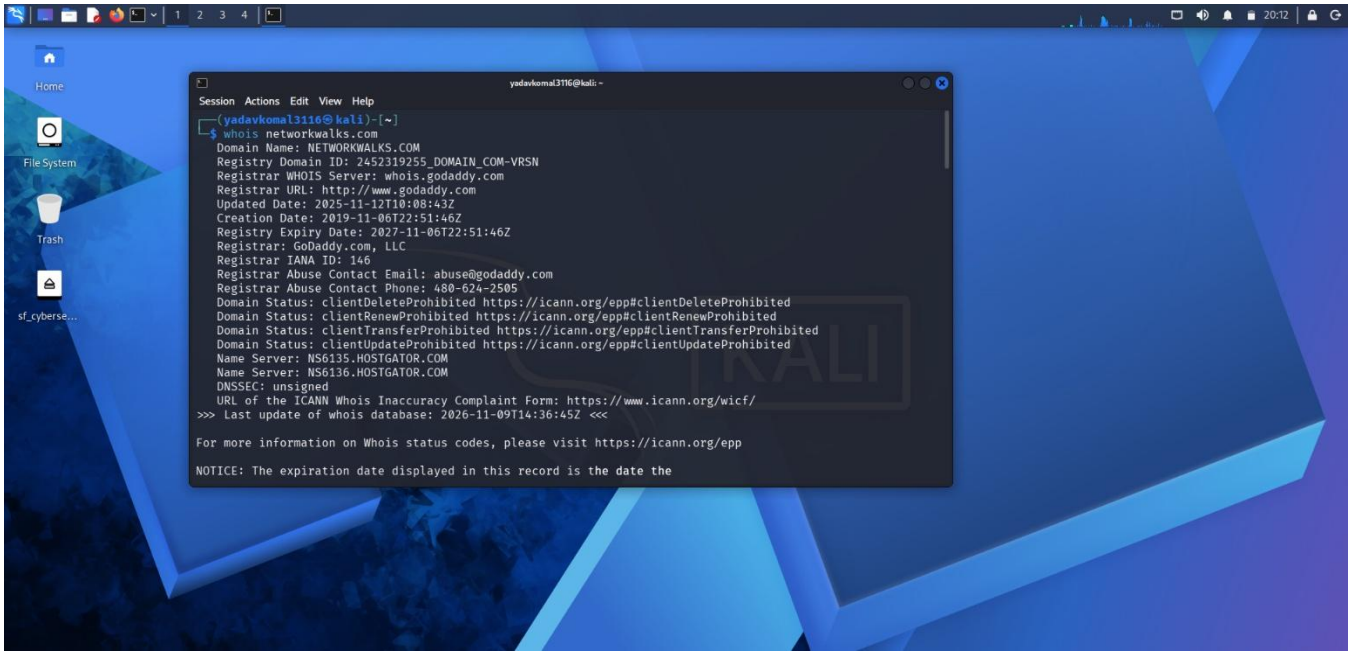


Figure 2: WhatWeb technology fingerprint (`whatweb networkwalks.com`)

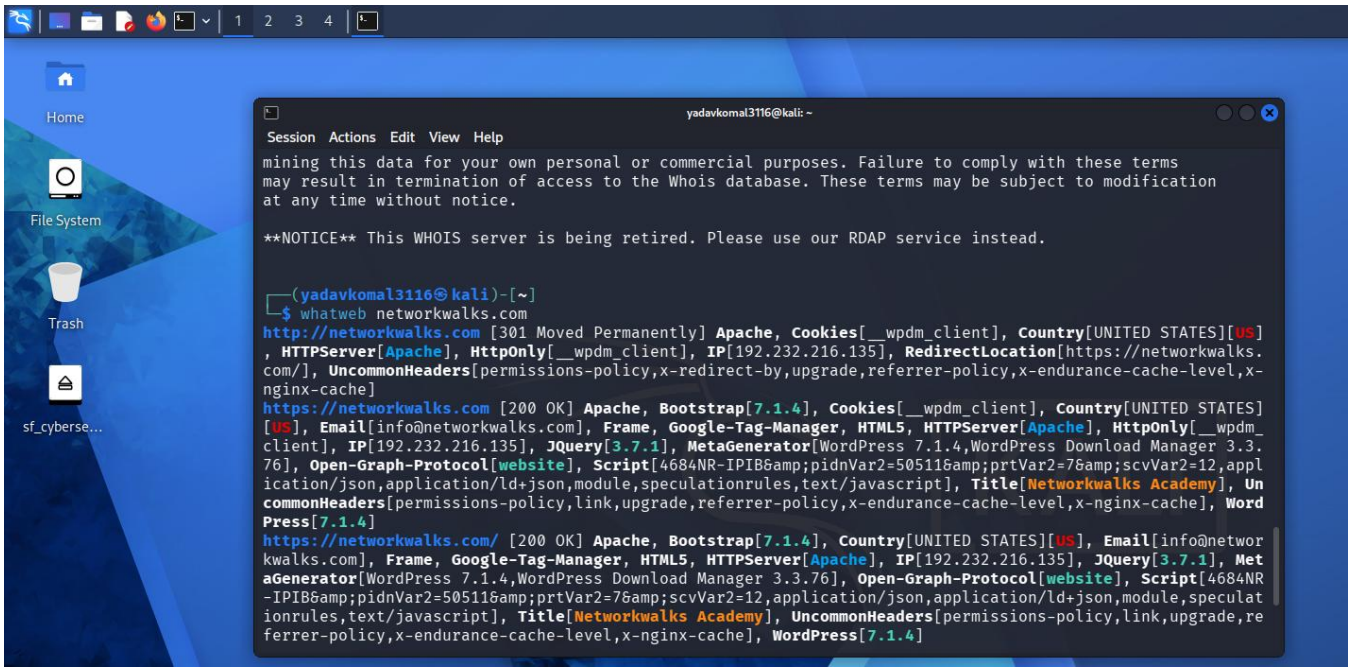


Figure 3: Nslookup IP resolution (`nslookup networkwalks.com`)

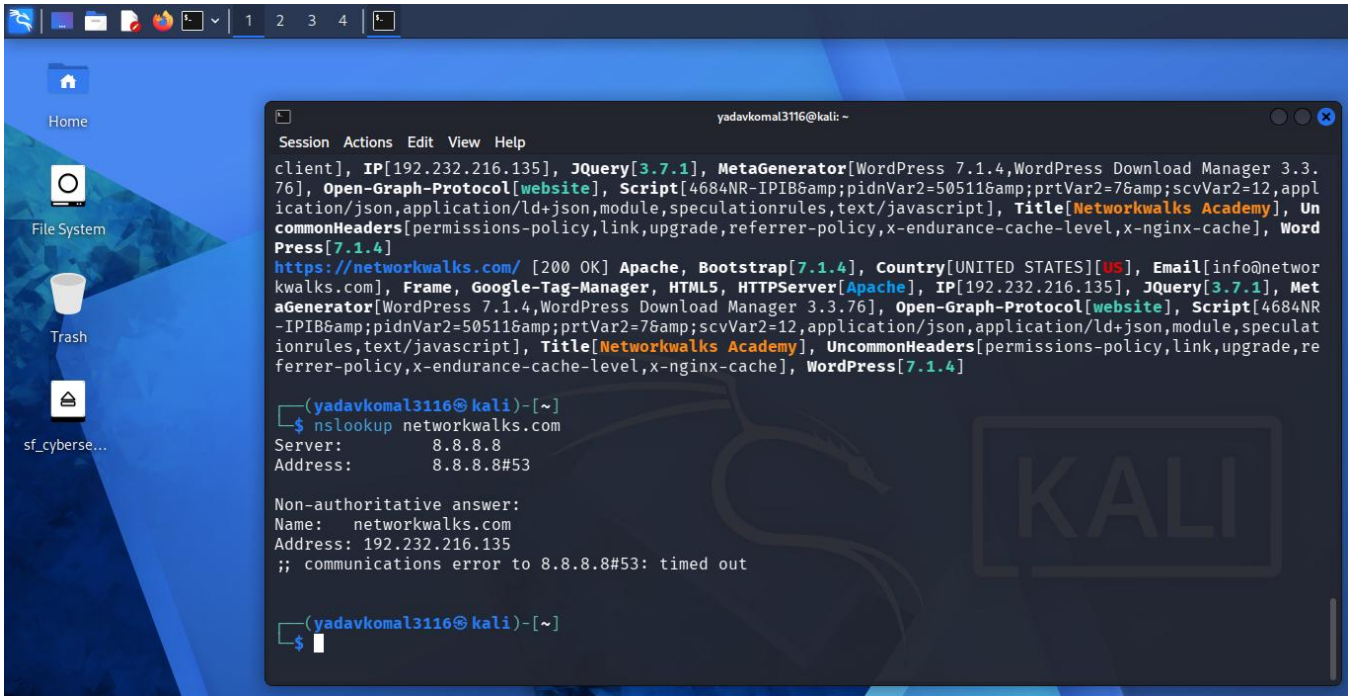


Figure 4: HTTP response headers (`curl -I https://networkwalks.com`)

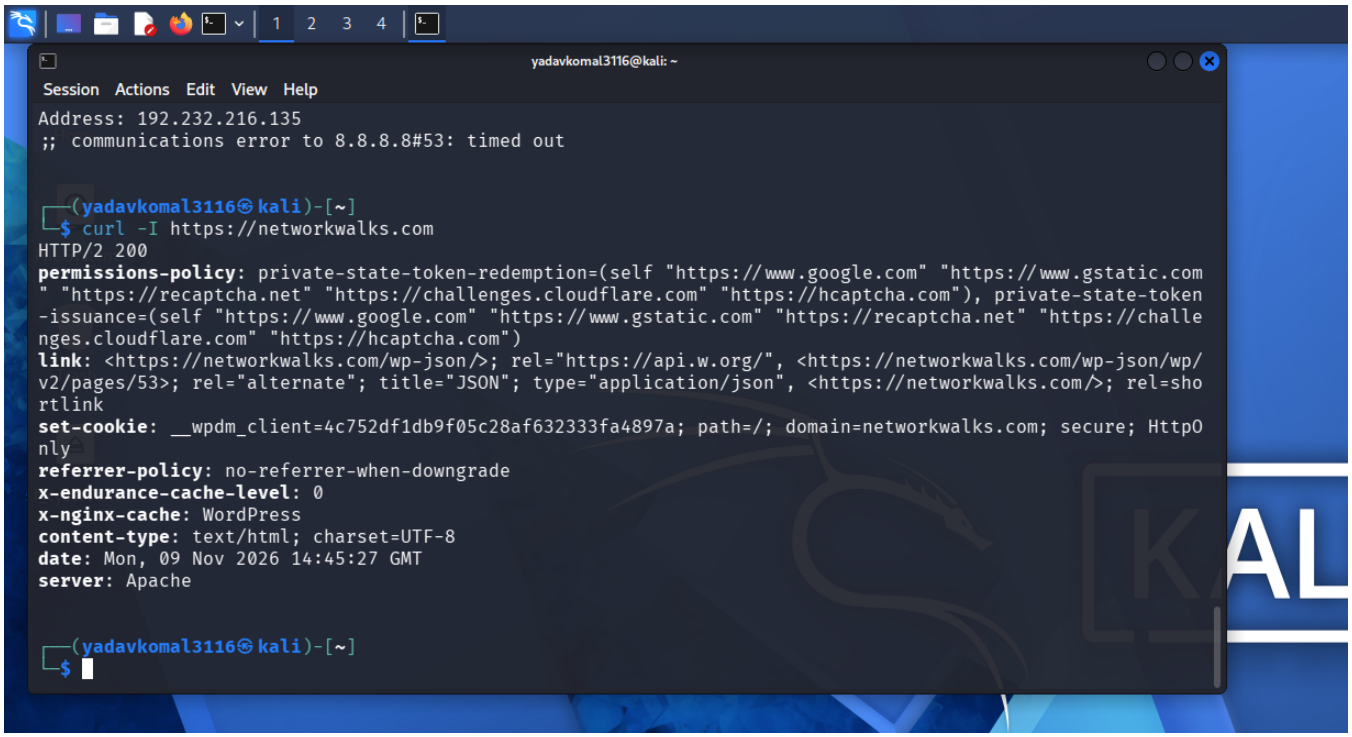


Figure 5: Wafw00f WAF detection (`wafw00f networkwalks.com`)

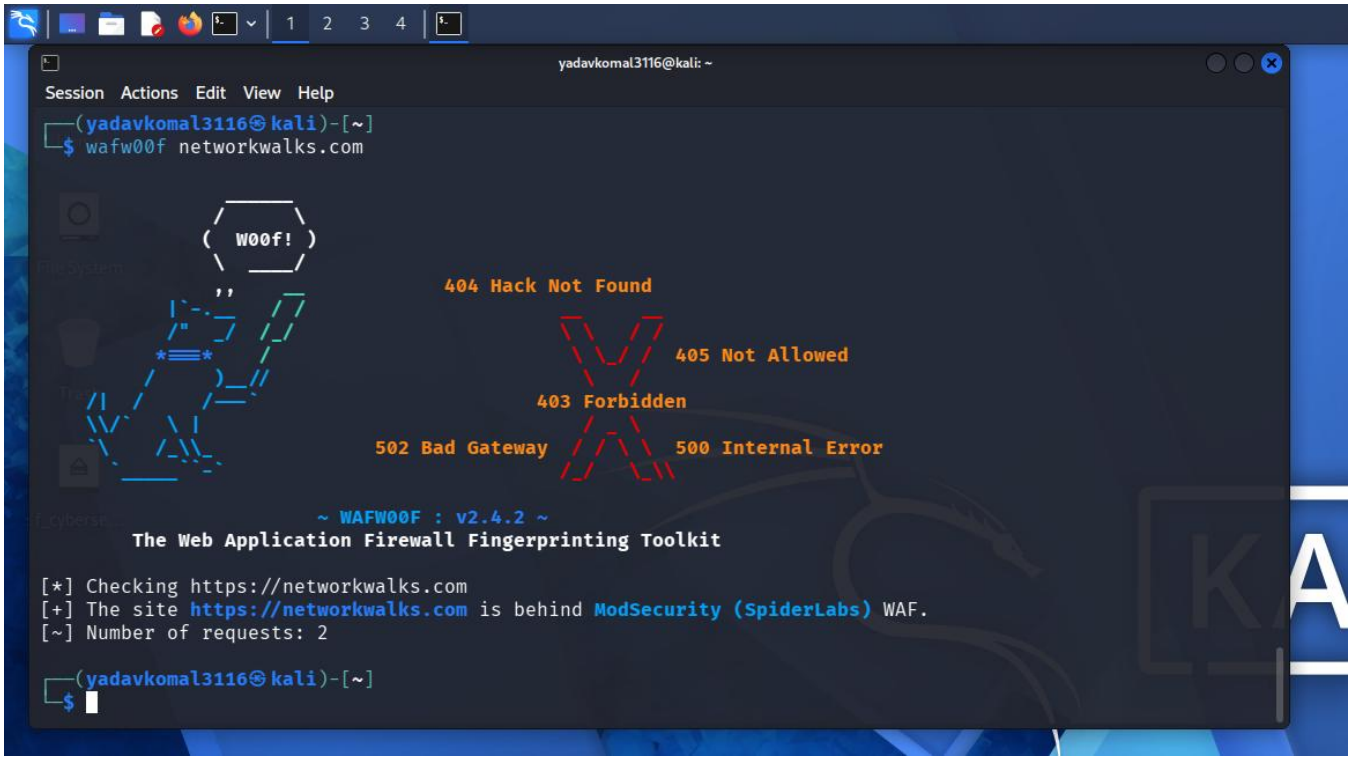


Figure 6: DNSRecon enumeration (`dnsrecon -d networkwalks.com`)

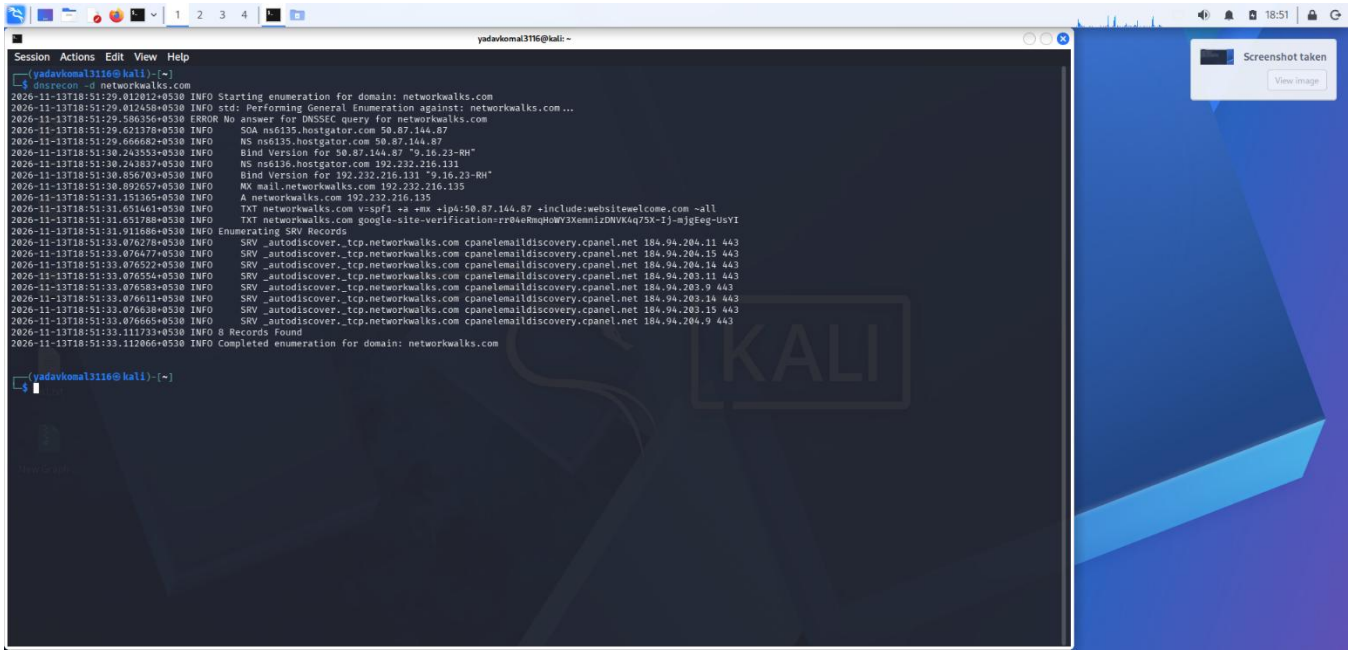


Figure 7: theHarvester run 1 (`theHarvester -d microsoft.com -l 1000 -b baidu`)

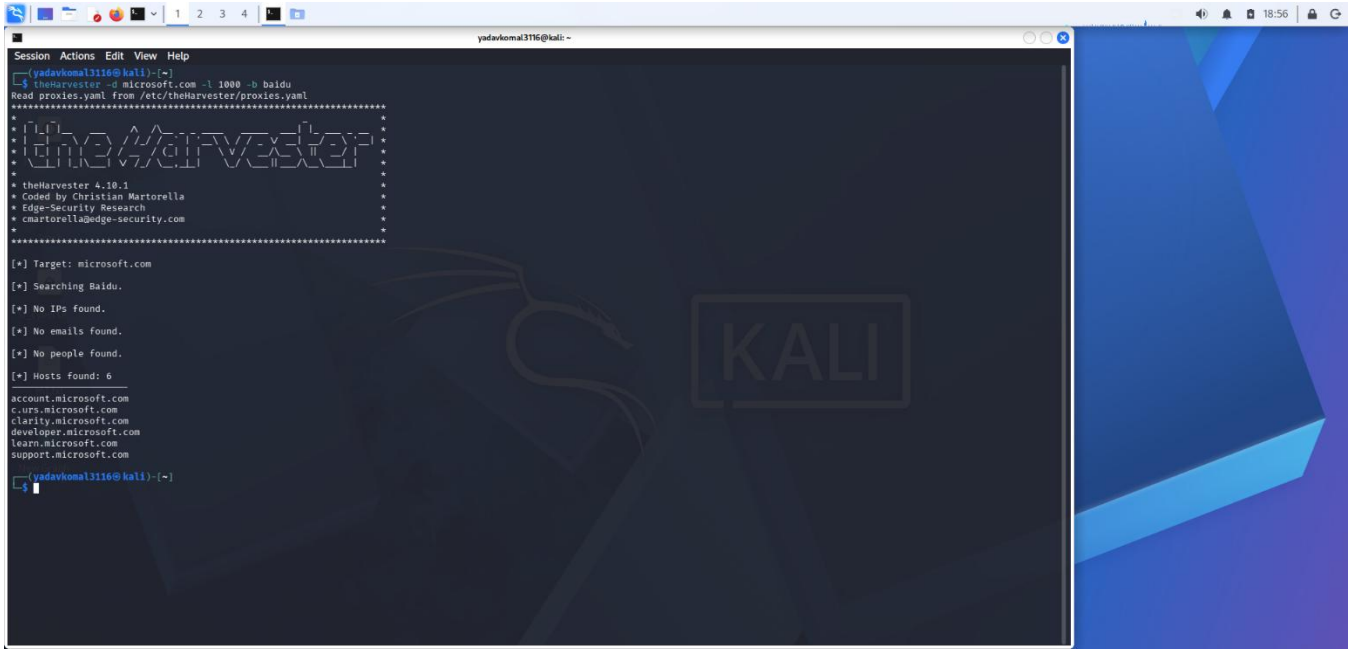


Figure 8: theHarvester run 2 (`theHarvester -d microsoft.com -l 50 -b all`)

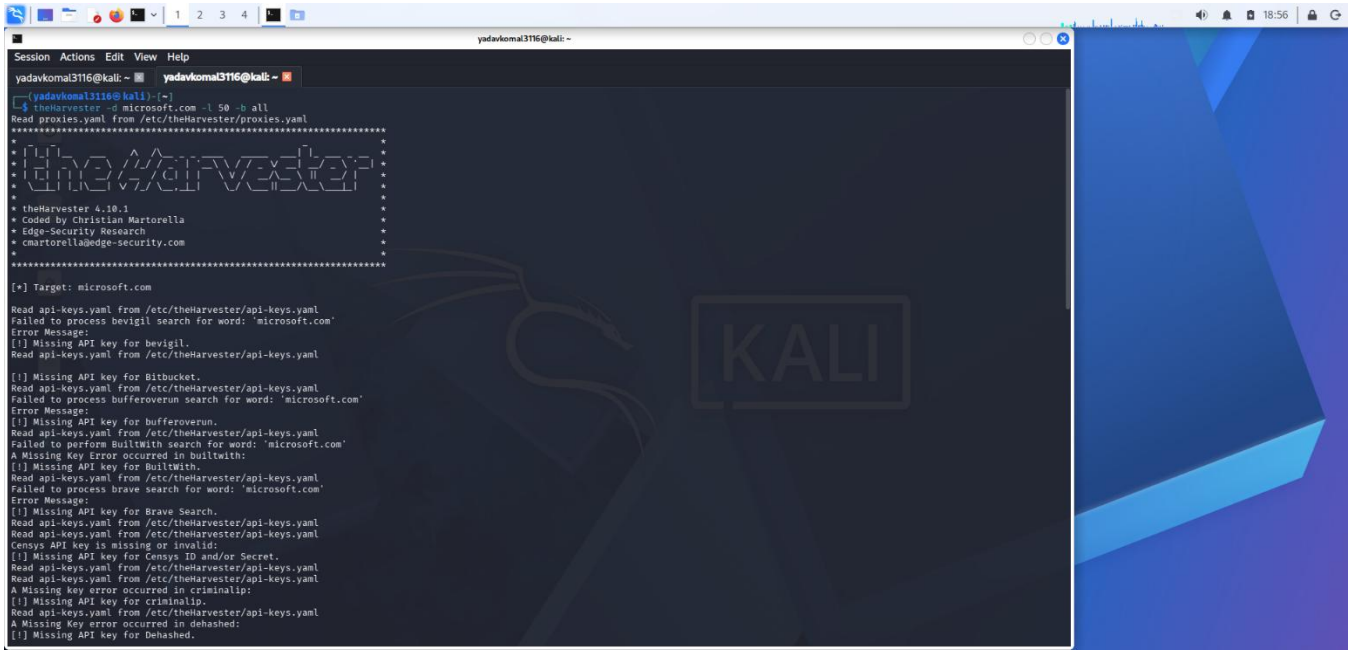


Figure 9: Local IP configuration in kali (`ip -4 addr and ip route`)

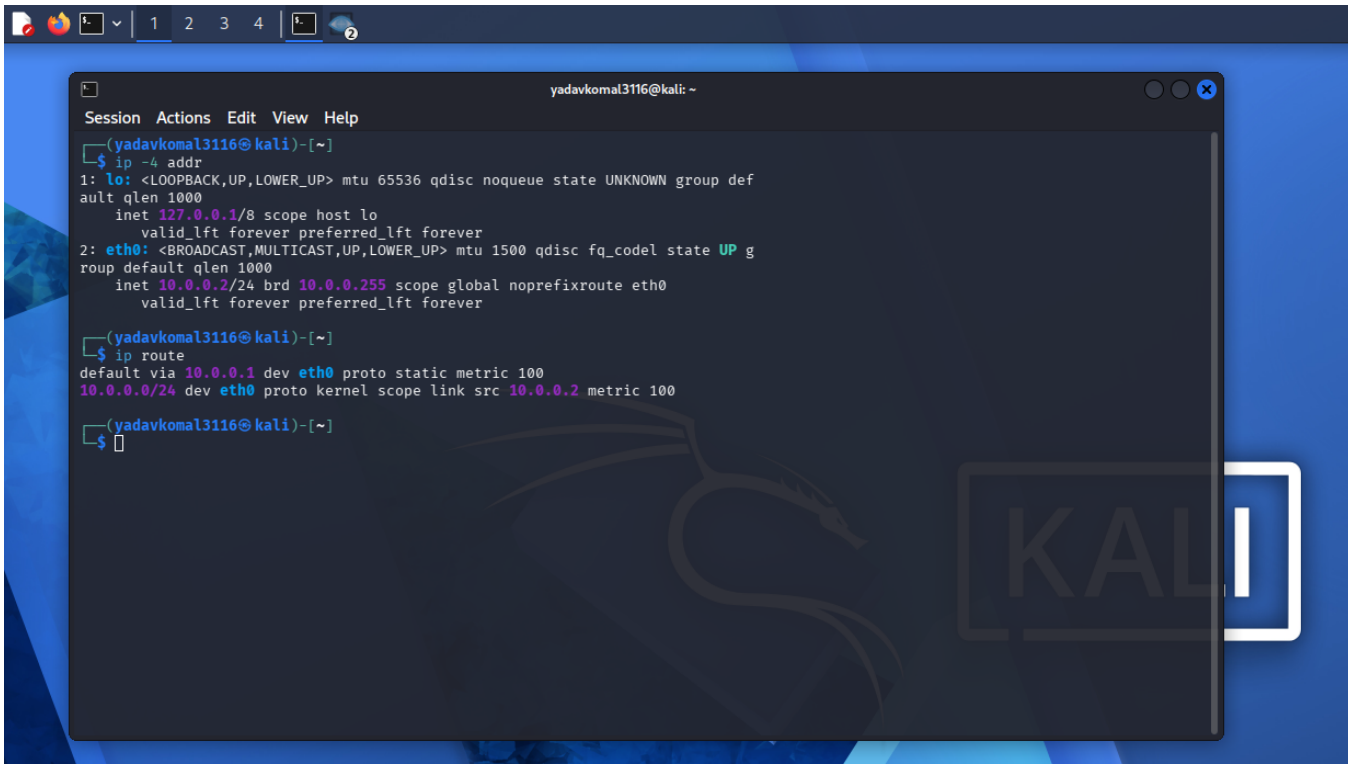


Figure 10: Zenmap Ping scan of 10.0.0.0/24 (`nmap -sn 10.0.0.0/24`)

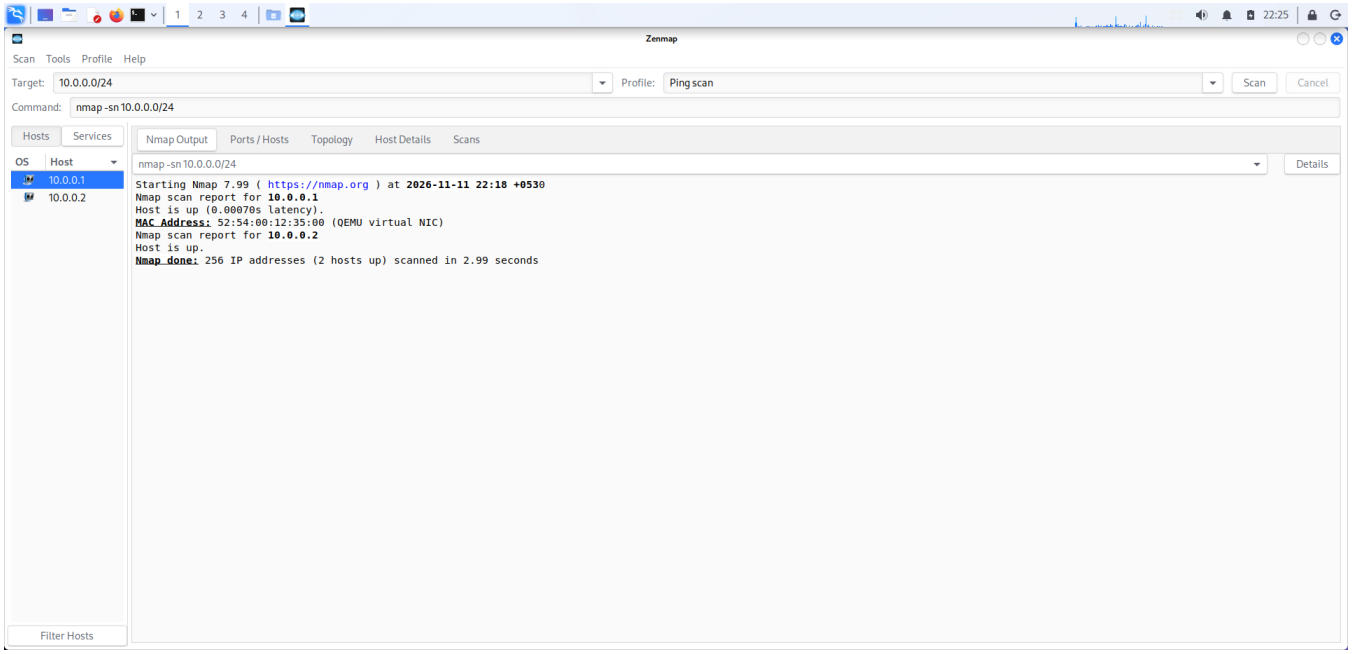


Figure 11: Network topology saved as PDF (`topo.pdf`)

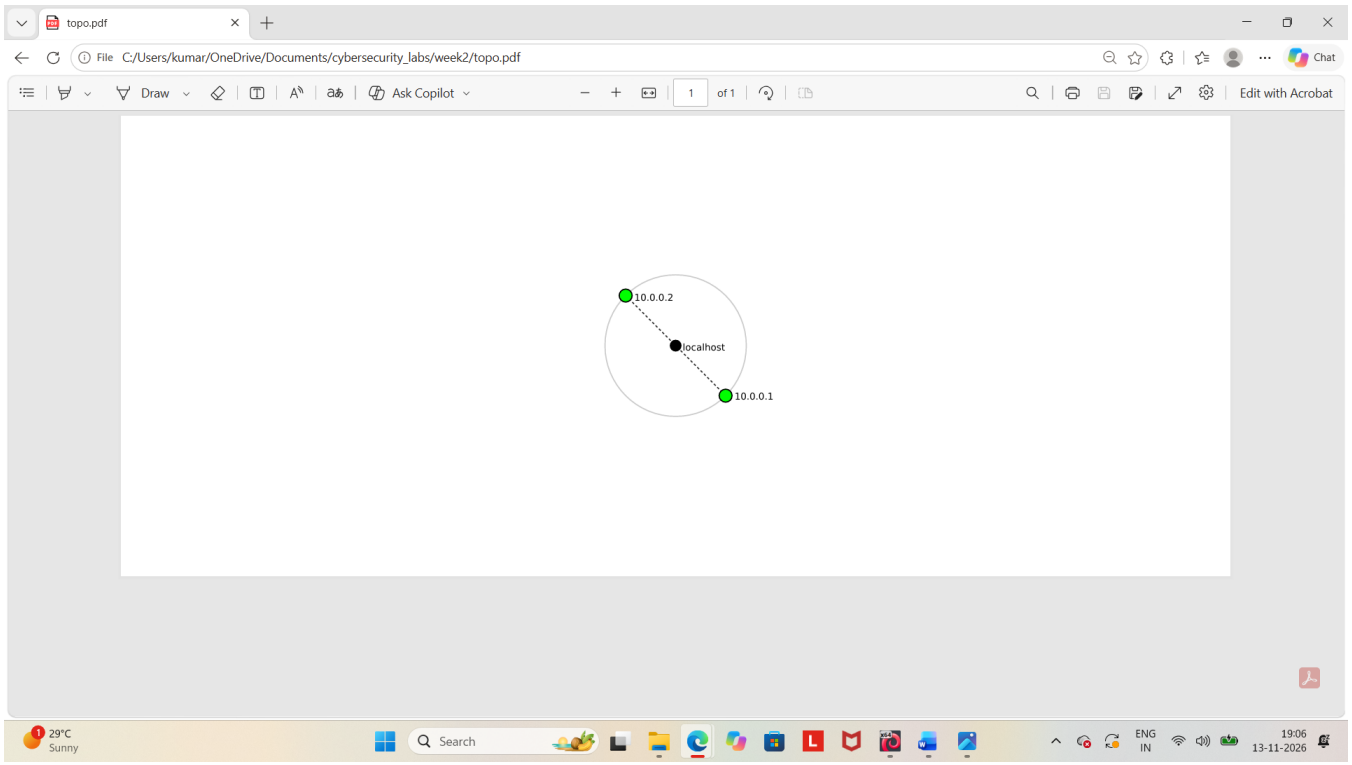
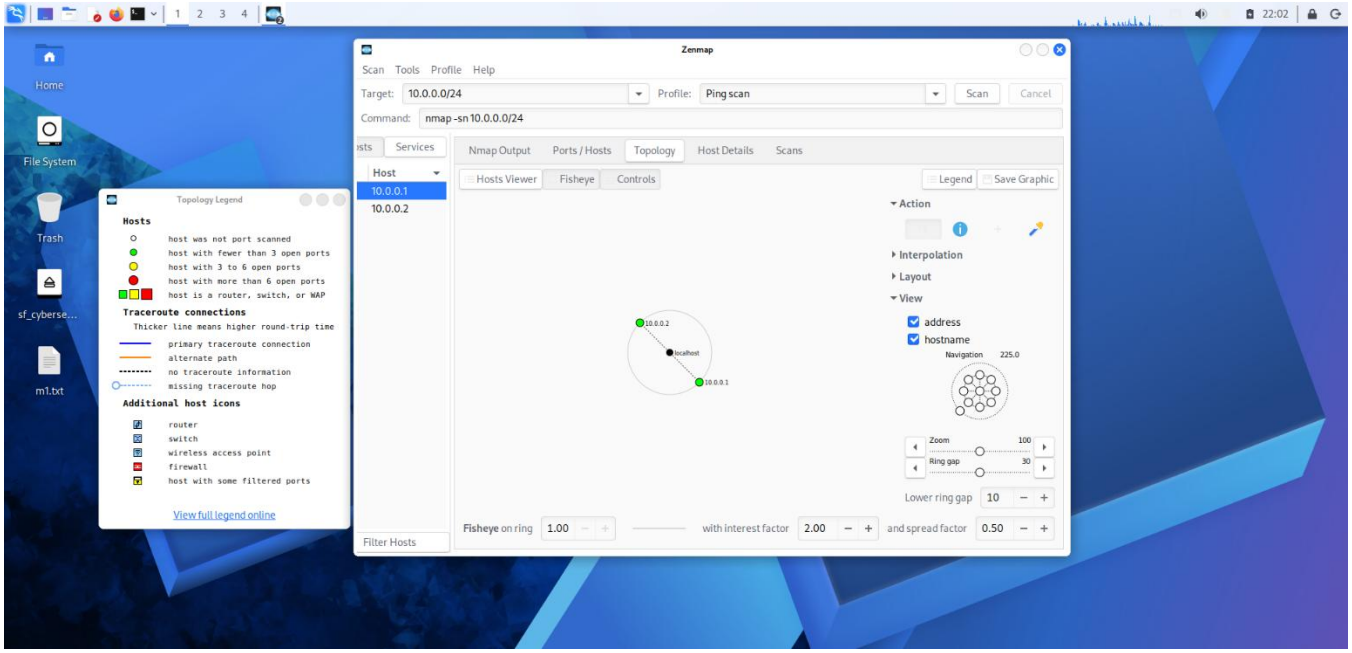


Figure 12: Zenmap Topology tab



-End-

👤 Author

KOMAL
Cybersecurity Professional B084B

📌 Project Information

Program Name: Cybersecurity program at Networkwalks | **Week:** 02 | **Repository:** GitHub